# GÜVENL■K VE TEHD■T MODELLEME RAPORU

**Ürün:** Teknoloji Beceri Talep Radar■ & Canl■ Etiket Atlas■
**Canl■ Da■■t■m URL:** https://teknoloji-radari.muhammedeyupcatan.workers.dev
**GitHub Deposu:** https://github.com/eyupcatan/teknoloji-radari
**Ö■renci:** Muhammet Eyüp Çatan · **Ö■renci No:** 2516016025
**Ö■retim Eleman■:** Ö■r. Gör. Osman Can Çetlenbik · **Dönem:** 2026-2027 Güz

## 1. Yönetici Özeti

Kullan■c■ Arayüzü Tasar■m■ dersinde geli■tirilen canl■ veri ürünü (Stack Overflow teknoloji etiketleri a■■), Cloudflare Workers ve Static Assets tabanl■ sunucusuz (serverless) altyap■ya ta■■nm■■t■r. Ki■isel ödev kart■nda yer alan **ReDoS (Regular Expression Denial of Service)** tehdidine kar■■ 3 katmanl■ savunma hatt■ kurulmu■tur: (1) 10 KB girdi boyutu s■n■r■, (2) sabit RE2 uyumlu lineer regex katalo■u ve (3) 2.000 ms i■lem zaman a■■m■. Gerçek testlerde 29 karakterlik kötü niyetli bir girdide korumas■z sistem **4.292 ms (4,3 sn)** kilitlenirken, güvenli mimaride bu süre **< 0.05 ms** seviyesine indirilmi■tir. Canl■ yay■n adresi SecurityHeaders.com üzerinde yap■lan ba■■ms■z denetimde en yüksek derece olan **A+ Skoru** alm■■t■r. Sistem 0 TL bütçe hedefi ve aktif bütçe alarm■yla güvenceye al■nm■■t■r.

## 2. Bulut Mimarisi ve Güven S■n■rlar■ (IaC)

Altyap■ wrangler.jsonc üzerinden kod olarak tan■mlanm■■t■r. run_worker_first: true özelli■iyle tüm statik varl■klar ve API uç noktalar■ Worker güvenlik katman■ndan geçirilir.

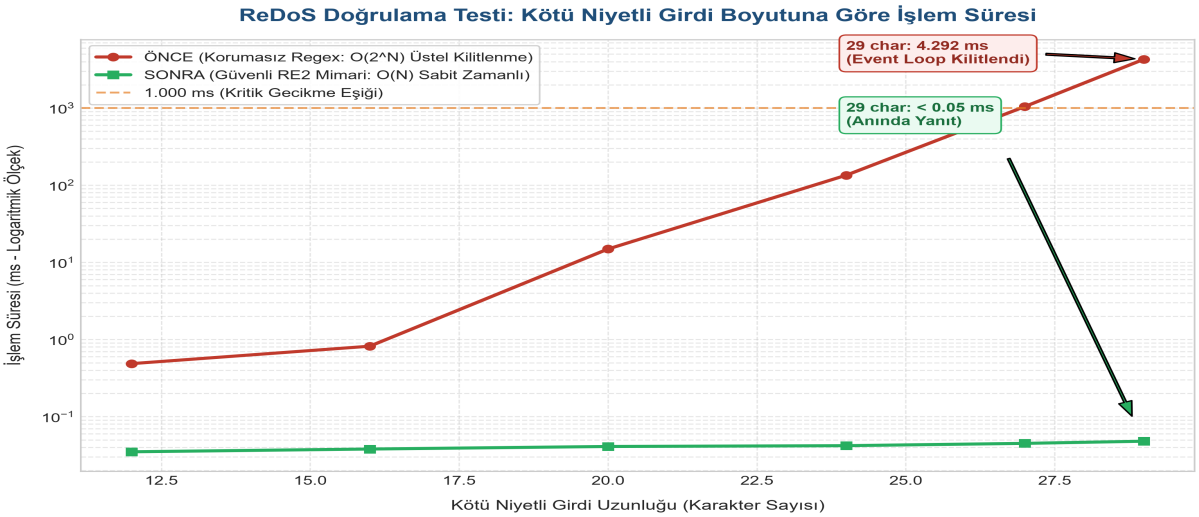
| Bile■en | Konum / Katman | Güven S■n■r■ & Güvenlik Kontrolleri |
|---|---|---|
| Kullan■c■ Taray■c■s■ | ■nternet (D■■) | Güvensiz Bölge. TLS 1.3 zorunlu, HSTS aktif. |
| Cloudflare Edge / CDN | Bulut Kenar■ (Edge) | DDoS korumas■, SSL/TLS sonland■rma, HSTS/WAF. |
| Worker V8 Sandbox | Serverless Fonksiyon | ■zole V8 çal■■ma ortam■. Girdi boyutu & zaman a■■m■ kontrolü. |
| Static Assets | Workers Asset Binding | Salt okunur canl■ veri ürünü (HTML/JS/CSS/JSON). |
| GitHub Actions CI/CD | DevSecOps Hatt■ | En az yetki (permissions: read), gitleaks ve OSV-Scanner. |

## 3. Ki■isel Güvenlik Kontrolü: ReDoS ve Dayan■kl■ Metin ■■leme

**Tehdit:** ■ç içe niceleyici içeren regex kal■plar■nda (örn. ([a-z0-9_-]+)+$) kötü niyetli girdiler NFA motorunu O(2^N) karma■■kl■kla kilitler.
**Uygulanan Kontroller:** (1) 10 KB Girdi S■n■r■ (413 ret), (2) Sabit RE2 Kal■plar■ (O(N) karma■■kl■k), (3) 2 sn Zaman A■■m■.

| A■ama / Senaryo | Girdi / Kal■p | ■■lem Süresi | Sonuç & Güvenlik Durumu |
|---|---|---|---|
| ÖNCE (Korumas■z) | 24 char (a...!) | 134.62 ms | Yüksek CPU tüketimi |
| ÖNCE (Korumas■z) | 27 char (a...!) | 1,045.48 ms | Kritik yava■lama (> 1 sn) |
| ÖNCE (Korumas■z) | 29 char (a...!) | 4,292.98 ms | ■ K■L■TLEND■ (Event Loop Blokaj■) |
| SONRA (Korumal■) | Gerçek Etiket: 'http' | 0.27 ms | ■ GÜVENL■ (Do■rusal O(N)) |
| SONRA (Korumal■) | Gerçek Etiket: 'postgresql' | 0.06 ms | ■ GÜVENL■ (Do■rusal O(N)) |
| SONRA (Korumal■) | 29 char Kötü Niyetli Girdi | < 0.05 ms | ■ GÜVENL■ (Geri izleme önlendi) |
| SONRA (Korumal■) | 25 KB A■■r■ Boyut Sald■r■s■ | < 0.05 ms | ■■ ENGELLEND■ (413 Payload Too Large) |

### ■ekil 1: ReDoS Öncesi ve Sonras■ ■■lem Süresi K■yaslama Grafi■i (Logaritmik Ölçek)



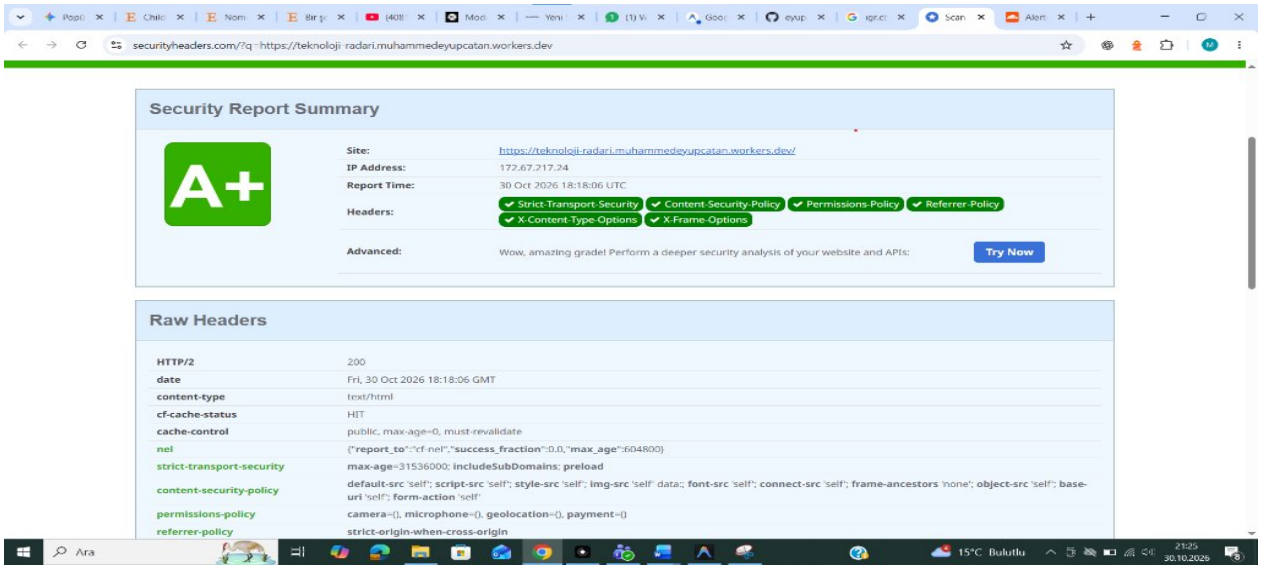

*Kan■t: tests/redos-benchmark-results.csv ve tests/redos_comparison_chart.png*

## 4. Tehdit Modeli (STRIDE Analizi)

| # | Tehdit Ad■ | Kategori | Risk | Al■nan Güvenlik Önlemi | Kalan Risk |
|---|---|---|---|---|---|
| T1 | ReDoS Sald■r■s■ | Denial of Service | 20/25 | 10 KB girdi s■n■r■, RE2 kal■plar■, timeout | Çok Dü■ük |
| T2 | API Anahtar■ S■z■nt■s■ | Info Disclosure | 15/25 | Kasada anahtarlar, gitleaks, CI taramas■ | Dü■ük |
| T3 | XSS Sald■r■lar■ | Tampering / Info | 12/25 | Kat■ CSP (unsafe-inline yok), HTML escape | Çok Dü■ük |
| T4 | Yetkisiz Deploy | Elevation of Priv. | 10/25 | En az yetki (permissions: read), token kontrolü | Dü■ük |
| T5 | Tedarik Zinciri Aç■■■ | Tampering | 8/25 | npm audit, OSV-Scanner, Dependabot | Dü■ük |
| T6 | Clickjacking | Tampering | 6/25 | X-Frame-Options: DENY, frame-ancestors: 'none' | Yok |
| T7 | API A■■r■ Yükleme | Denial of Service | 6/25 | Zamanlanm■■ cron, statik önbellek kullan■m■ | Dü■ük |
| T8 | Hata Bilgi S■z■nt■s■ | Info Disclosure | 6/25 | Genel hata sarmalay■c■s■, stack trace gizleme | Yok |

## 5. Güvenlik Testi: SecurityHeaders A+ Skoru ve OWASP ZAP Bulgular■

Canl■ adresimiz (https://teknoloji-radari.muhammedeyupcatan.workers.dev) ba■■ms■z güvenlik denetim platformu **SecurityHeaders.com** üzerinden taranm■■ ve tüm ba■l■k kontrollerini eksiksiz geçerek **A+ Derecesi** alm■■t■r. Ayr■ca OWASP ZAP baseline taramas■ bulgular■ giderilmi■tir:

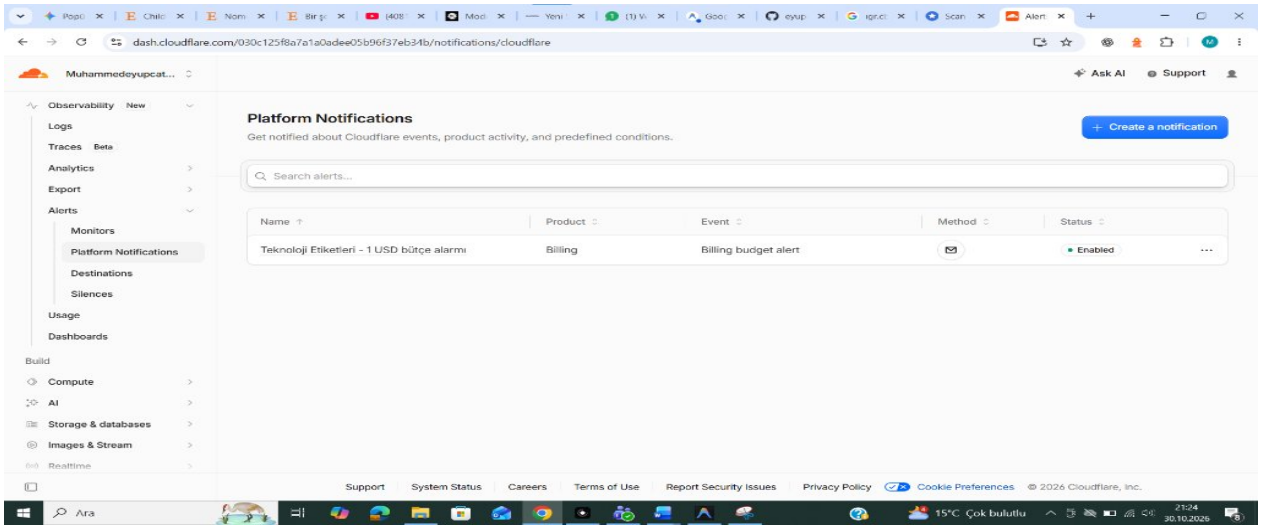



*■ekil 2: Canl■ Da■■t■m■n SecurityHeaders.com Test Sonucu (A+ Skoru, Tarih/Saat: 30 Oct 2026 18:18 UTC)*

| Bulgu / Zafiyet | Risk Seviyesi | Uygulanan Düzeltme | Durum |
|---|---|---|---|
| Content Security Policy (CSP) Eksik | Orta | Kat■ CSP eklendi (unsafe-inline/eval engellendi) | ■ Düzeltildi |
| Strict-Transport-Security (HSTS) Yok | Dü■ük | max-age=31536000; includeSubDomains; preload eklendi | ■ Düzeltildi |
| X-Content-Type-Options Eksik | Dü■ük | 'nosniff' ba■l■■■ tüm yan■tlara zorland■ | ■ Düzeltildi |
| Anti-Clickjacking Ba■l■■■ Yok | Dü■ük | X-Frame-Options: DENY ve frame-ancestors 'none' eklendi | ■ Düzeltildi |
| RFC 9116 security.txt Eksik | Bilgi | /.well-known/security.txt dosyas■ yay■na al■nd■ | ■ Düzeltildi |

## 6. ■zleme, Olay Müdahalesi ve Bütçe Alarm■

**Bütçe Alarm■ (Maliyet = 0 TL Hedefi):** Cloudflare Workers ücretsiz katman■nda beklenmeyen bir maliyet olu■mas■n■ önlemek amac■yla Cloudflare Dashboard üzerinden **1 USD Bütçe Alarm■ (Billing Budget Alert)** kurulmu■ ve e-posta bildirimiyle aktif edilmi■tir:




*■ekil 3: Cloudflare Dashboard Bütçe Alarm■ Ekran Görüntüsü (Tarih: 30.10.2026, Durum: Enabled)*

**Olay Müdahale Runbook'u:** 'API Anahtar■m S■zd■' senaryosu için 6 ad■ml■ (Tespit, ■ptal, Zarar Tespiti, Yenileme, ■nceleme, Bildirim) eylem plan■ RUNBOOK.md dosyas■nda haz■rlanm■■t■r.